12 · Control Deep Dives: Examples & What to Look For

A per-control field manual for security architects and technical SMEs. Each section adds what a doc-06 field guide entry only points at: **real-world examples** (from the exploit catalog and the incident catalogue), **what to look for in a typical deployment**, and the **L3 bar**. Every fact derives from the committed policies, exploit catalog, and incident catalogue – no general-knowledge claims.

Contents

- **EE · Execution Environment** (8 controls)
  - EE-01 — Execution environment boundary enforcement
  - EE-02 — Infrastructure API access control
  - EE-03 — Resource usage limiting
  - EE-04 — Evaluation sandbox integrity
  - EE-05 — Host-trusted configuration file injection prevention
  - EE-06 — Fail-closed sandbox operation
  - EE-07 — Agent control-plane configuration integrity
  - EE-08 — Evaluation-harness isolation and integrity
- **MS · Model Security** (15 controls)
  - MS-01 — Model weight protection
  - MS-02 — Training data integrity
  - MS-03 — Supply chain security
  - MS-04 — Adversarial robustness
  - MS-05 — Model behaviour validation
  - MS-06 — Model inventory and lineage tracking
  - MS-07 — Deployment context obfuscation
  - MS-08 — MCP

- MS-09 — Perception-fidelity enforcement for human-in-the-loop approvals
- MS-10 — Agent memory-store integrity
- MS-11 — Operational data-stream integrity
- MS-12 — MCP discovery-metadata and shared-cache integrity
- MS-13 — Transcript and conversation authenticity
- MS-14 — Self-replication barrier
- MS-15 — Cross-tenant agent memory and state isolation

- **IAM · Identity & Access** (10 controls)
  - IAM-01 — Agent identity management
  - IAM-02 — Scope-bound delegation
  - IAM-03 — Human oversight controls
  - IAM-04 — Credential isolation
  - IAM-05 — Just-in-time access
  - IAM-06 — Cross-session boundary enforcement
  - IAM-07 — Transitive delegation chain enforcement
  - IAM-08 — Credential scope narrowing
  - IAM-09 — Multi-tenant agent platform isolation
  - IAM-10 — Taint-tracked least-privilege subagent scoping
- **DS · Data Security** (8 controls)
  - DS-01 — Data classification and labelling
  - DS-02 — Inference data protection
  - DS-03 — Memory sanitisation
  - DS-04 — Data minimisation
  - DS-05 — Training data governance
  - DS-06 — Output validation
  - DS-07 — Agent-originated artifact publication control
  - DS-08 — Destination and emergent-channel egress inventory
- **TP · Tool & Pipeline Security** (16 controls)
  - TP-01 — Tool inventory and registry
  - TP-02 — Tool access control
  - TP-03 — API gateway security

- TP-04 — Tool output validation
- TP-05 — Pipeline integrity
- TP-06 — Dependency scanning
- TP-07 — Cross-tool dependency analysis
- TP-08 — API gateway infrastructure-isolation mode
- TP-09 — Explicit tool registration — no implicit tool exposure
- TP-10 — Agent platform inbound control-plane protection
- TP-11 — Agent browser and content-rendering isolation
- TP-12 — Tool-call provenance and dispatch verification
- TP-13 — Agent dependency-install provenance verification
- TP-14 — Skill/plugin payload integrity and instruction-channel isolation
- TP-15 — In-process code-execution sandbox sufficiency
- TP-16 — Tool-connection and launch-path integrity

- **MIR · Monitoring, Logging & IR** (6 controls)
  - MIR-01 — Agent activity logging
  - MIR-02 — Anomaly detection
  - MIR-03 — Prompt audit log
  - MIR-04 — Incident response
  - MIR-05 — Mandatory reporting integration
  - MIR-06 — Forensic readiness
- **GRM · Governance & Risk** (6 controls)
  - GRM-01 — AI governance body
  - GRM-02 — AI risk register
  - GRM-03 — Ethical use policy
  - GRM-04 — Third-party AI risk management
  - GRM-05 — Regulatory mapping and compliance reporting
  - GRM-06 — Board and executive reporting

EE · Execution Environment

EE-01: Execution environment boundary enforcement

Execution environment boundary enforcement must hold. Enforce a hard execution boundary around every agent.

Real-world examples from the exploit catalog:

- **G01 — Execution-Environment Escape (Container / VM Sandbox Breakout):** catalogued attack pattern that exercises this control. CVEs: CVE-2026-77179 · CVE-2026-79994 · CVE-2026-32193 · CVE-2026-53359 (Januscape). Canonical incidents: INC-01, INC-02, INC-03, INC-05.
- **G27 — In-Process Denylist/Blocklist Code-Execution Sandbox Bypass:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-47392 (PraisonAI · Critical) · CVE-2026-37008 (CrewAI · 8.1). Canonical incidents: INC-58, INC-68, INC-74, INC-76.
- **G34 — Cross-Tenant Isolation in Pooled Agent Memory and Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-2018 · CVE-2026-2104 · CVE-2026-120306 · CVE-2026-120307. Canonical incidents: INC-81.
- Further evidenced by 14 catalogue incident(s): INC-11, INC-13, INC-17, INC-18, INC-23, INC-29.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.tool, input.agent.sandboxed (bool).` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): No shared host mounts or namespaces; immutable infrastructure; fail-closed on breach..

Often verified together: EE-02, EE-03, EE-04, EE-05.

EE-02: Infrastructure API access control

Infrastructure API access control must hold. Ensure agents cannot reach infrastructure control planes implicitly.

Real-world examples from the exploit catalog:

- **G03 — Infrastructure API vs Tool API Confusion:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-04, INC-07.
- Further evidenced by 3 catalogue incident(s): INC-39, INC-60, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.tool = the API being called;` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Explicit tool registration required for infrastructure access; metadata service disabled; blocked attempts logged..

Often verified together: EE-01, EE-03, EE-04, EE-05.

EE-03: Resource usage limiting

Resource usage limiting must hold. Bound agent resource consumption with runtime enforcement.

Real-world examples from the exploit catalog:

- **G01 — Execution-Environment Escape (Container / VM Sandbox Breakout):** catalogued attack pattern that exercises this control. CVEs: CVE-2026-77179 · CVE-2026-79994 · CVE-2026-32193 · CVE-2026-53359 (Januscape). Canonical incidents: INC-01, INC-02, INC-03, INC-05.
- Further evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.resource_usage = {"cpu_pct": n, "network_mbps": n,` and

fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Runtime-enforced limits (CPU, memory, storage, network, API rate); exceeding limits alerts and may terminate..

Often verified together: EE-01, EE-02, EE-04, EE-05.

EE-04: Evaluation sandbox integrity

Evaluation sandbox integrity must hold. Contain the blast radius of model behaviour during evaluation.

Real-world examples from the exploit catalog:

- **G06 — Evaluation and Test Sandbox Controls:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01.
- Further evidenced by 3 catalogue incident(s): INC-19, INC-90, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "evaluation_run";` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): No network path between evaluation and production; evaluation pipelines cannot modify production..

Often verified together: EE-01, EE-02, EE-03, EE-05.

EE-05: Host-trusted configuration file injection prevention

Host-trusted configuration file injection prevention must hold. Prevent indirect sandbox escape via host-trusted file injection.

Real-world examples from the exploit catalog:

- **G08 — Host-Trusted File Injection (Indirect Sandbox Escape):** catalogued attack pattern that exercises this control. CVEs: CVE-2026-48124 · CVE-2026-50548 · CVE-2026-50549 |. Canonical incidents: INC-11.
- Further evidenced by 10 catalogue incident(s): INC-03, INC-11, INC-14, INC-15, INC-41, INC-57.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.config.path_writable = paths the agent can write.` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Host-trusted paths excluded from agent writes; FIM on host-trusted directories; content scanning..

Often verified together: EE-01, EE-02, EE-03, EE-04.

EE-06: Fail-closed sandbox operation

Fail-closed sandbox operation must hold. Eliminate silent fallback to weaker sandboxes.

Real-world examples from the exploit catalog:

- **G10 — Fail-Open Sandbox Fallback:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-13.
- Further evidenced by 3 catalogue incident(s): INC-21, INC-61, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "code_execution";` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Runtime attestation before each execution; no fallback path; fail-closed on unavailability; alerts on degradation..

Often verified together: EE-01, EE-02, EE-03, EE-04.

EE-07: Agent control-plane configuration integrity

Agent control-plane configuration integrity must hold. Prevent agents from disabling their own security controls.

Real-world examples from the exploit catalog:

- **G11 — Agent Control-Plane Configuration Integrity:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-35603 · CVE-2026-12537 · CVE-2026-54316 · CVE-2026-72718. Canonical incidents: INC-14, INC-15, INC-46, INC-53.
- **G14 — Inbound Agent-Platform Control-Plane Hijack:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-25253 · CVE-2026-59726 · CVE-2026-65105 · CVE-2026-82533. Canonical incidents: INC-21, INC-23, INC-24, INC-31.
- **G16 — Agent-Originated Artifact Publication:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-20.
- Further evidenced by 12 catalogue incident(s): INC-03, INC-15, INC-20, INC-39, INC-46, INC-53.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.config = {"path_writable": [..],` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Control-plane config read-only to the agent; world-writable paths rejected; integrity monitoring on control files..

Often verified together: EE-01, EE-02, EE-03, EE-04.

EE-08: Evaluation-harness isolation and integrity

Evaluation-harness isolation and integrity must hold. Ensure evaluation harnesses are genuinely isolated and monitored, with isolation verified rather than asserted.

Real-world examples from the exploit catalog:

- **G17 — Evaluation-Harness Integrity:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-01, INC-26, INC-27.
- Further evidenced by 10 catalogue incident(s): INC-26, INC-27, INC-28, INC-32, INC-40, INC-62.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "evaluation_run";` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Policy-as-code isolation attestation; GA classifiers and monitoring in eval environments; automated collision checks..

Often verified together: EE-01, EE-02, EE-03, EE-04.

MS · Model Security

MS-01: Model weight protection

Model weight protection must hold. Ensure model weights are protected against exfiltration, cloning, and inversion attacks through encryption, access control, and integrity verification.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.model = {"weights_encrypted": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-02, MS-03, MS-04, MS-05.

MS-02: Training data integrity

Training data integrity must hold. Ensure training and fine-tuning datasets are verified for integrity, provenance, and freedom from poisoning or corruption before use.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.training = {"provenance_tracked": bool, "sanitised": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-01, MS-03, MS-04, MS-05.

MS-03: Supply chain security

Supply chain security must hold. Verify the provenance and integrity of model weights, ML libraries, training infrastructure, and deployment tooling throughout the AI supply chain.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 3 catalogue incident(s): INC-01, INC-19, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.model.supply_chain = {"sbom": bool, "signature_verified": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-01, MS-02, MS-04, MS-05.

MS-04: Adversarial robustness

Adversarial robustness must hold. Test and verify that models resist prompt injection, jailbreaking, and other adversarial inputs through automated testing, red-teaming, and proxy-layer guardrails.

Real-world examples from the exploit catalog:

- **G15 — Imperceptible-Content Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-20, INC-22, INC-25, INC-27.
- Further evidenced by 19 catalogue incident(s): INC-03, INC-08, INC-09, INC-12, INC-13, INC-14.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.context.content[] = agent-visible content the action is` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Automated adversarial test suite in CI/CD. Quarterly red-teaming. Output guardrails at proxy layer..

Often verified together: MS-01, MS-02, MS-03, MS-05.

MS-05: Model behaviour validation

Model behaviour validation must hold. Validate that model outputs conform to expected safety, content, and scope boundaries through proxy-layer guardrails and per-agent behaviour configuration.

Real-world examples from the exploit catalog:

- **G05 — Deployment-Context Awareness:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-06.
- Further evidenced by 4 catalogue incident(s): INC-06, INC-08, INC-09, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.guardrail_evaluated (bool); input.action.scope_compliant` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-06: Model inventory and lineage tracking

Model inventory and lineage tracking must hold. Maintain a complete, versioned inventory of all models with traceable lineage from training through deployment to retirement.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-06.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.model.inventory = {"registered": bool, "lineage_tracked": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-07: Deployment context obfuscation

Deployment context obfuscation must hold. Prevent models from detecting evaluation environments and behaving differently than in production.

Real-world examples from the exploit catalog:

- **G05 — Deployment-Context Awareness:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-06.
- Further evidenced by 2 catalogue incident(s): INC-19, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.evaluation = {"env_indistinguishable": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-08: MCP

MCP must hold. Secure the MCP protocol layer for agent-tool communication.

Real-world examples from the exploit catalog:

- **G09 — MCP Protocol-Layer Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-12, INC-37, INC-54.
- **G16 — Agent-Originated Artifact Publication:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-20.
- **G24 — MCP Discovery-Metadata and Shared-Cache Injection:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-75130 (Context7) |. Canonical incidents: INC-37.

- **G33 — Tool-Connection and Launch-Path Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2025-6514 · CVE-2026-103572 · CVE-2026-123022 · CVE-2026-110186. Canonical incidents: INC-79, INC-80, INC-85, INC-86.
- Further evidenced by 19 catalogue incident(s): INC-12, INC-20, INC-37, INC-39, INC-43, INC-54.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "mcp_connect";` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Signed tool metadata; response validation against known-good schemas; trusted MCP registry..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-09: Perception-fidelity enforcement for human-in-the-loop approvals

Perception-fidelity enforcement for human-in-the-loop approvals must hold. Ensure human-in-the-loop approval is never gated on content the human cannot perceive.

Real-world examples from the exploit catalog:

- **G15 — Imperceptible-Content Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-20, INC-22, INC-25, INC-27.
- **G30 — Agent-Identity Outbound Communication Attribution and Confirmation:** catalogued attack pattern that exercises this control. CVEs: None (architectural) |. Canonical incidents: INC-72.
- Further evidenced by 10 catalogue incident(s): INC-25, INC-27, INC-30, INC-36, INC-41, INC-55.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.approval = {"present": bool, "snapshot_fidelity_verified":` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Policy-as-code fidelity checks pre-approval; multimodal sanitisation; hidden-content stripping before agent context..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-10: Agent memory-store integrity

Agent memory-store integrity must hold. Ensure agent persistent memory cannot be silently poisoned to steer future behaviour.

Real-world examples from the exploit catalog:

- **G20 — Agent Memory-Store Poisoning:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-59726 (CVSS 10.0) · CVE-2026-65105 |. Canonical incidents: INC-31.
- **G27 — In-Process Denylist/Blocklist Code-Execution Sandbox Bypass:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-47392 (PraisonAI · Critical) · CVE-2026-37008 (CrewAI · 8.1). Canonical incidents: INC-58, INC-68, INC-74, INC-76.
- **G34 — Cross-Tenant Isolation in Pooled Agent Memory and Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-2018 · CVE-2026-2104 · CVE-2026-120306 · CVE-2026-120307. Canonical incidents: INC-81.
- Further evidenced by 7 catalogue incident(s): INC-31, INC-33, INC-45, INC-70, INC-81, INC-91.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "memory_write";` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Tamper-evident memory (append-only or immutable snapshots); anomaly detection on memory writes via MIR-02; retrieval-layer filtering of flagged entries; documented post-incident memory audit-and-clean procedure..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-11: Operational data-stream integrity

Operational data-stream integrity must hold. Prevent poisoned logs, alerts, and observability feeds from commanding the agent.

Real-world examples from the exploit catalog:

- **G22 — Operational Data-Stream Poisoning:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-33.
- Further evidenced by 4 catalogue incident(s): INC-33, INC-40, INC-67, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.trigger == "log_alert" when the action's proximate` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Agent-visible operational content sanitised for instruction-bearing payloads before reasoning; independent non-log verification for log-triggered actions; ingestion pipelines authenticate producers; MIR-02 flags log-origin agent actions..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-12: MCP discovery-metadata and shared-cache integrity

MCP discovery-metadata and shared-cache integrity must hold. Prevent MCP discovery metadata and shared caches from injecting instructions into agent system prompts.

Real-world examples from the exploit catalog:

- **G09 — MCP Protocol-Layer Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-12, INC-37, INC-54.
- **G24 — MCP Discovery-Metadata and Shared-Cache Injection:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-75130 (Context7) |. Canonical incidents: INC-37.
- Further evidenced by 3 catalogue incident(s): INC-37, INC-43, INC-92.

What to look for in a typical deployment:

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Instructions isolated from the trusted system prompt with explicit boundaries and length limits; cache keys bind to authenticated identity; cacheScope claims verified; tool metadata pinned to a baseline with drift alerting..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-13: Transcript and conversation authenticity

Transcript and conversation authenticity must hold. Make the harness's record of model output tamper-evident and authentic at the model boundary.

Real-world examples from the exploit catalog:

- **G28 — Agent Transcript / Conversation-History Authenticity:** catalogued attack pattern that exercises this control. CVEs: None (architectural; vendor-side signing required) |.
- Further evidenced by 3 catalogue incident(s): INC-70, INC-83, INC-92.

What to look for in a typical deployment:

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

- **The L3 bar** (the maturity target): Model outputs signed at the API/proxy boundary (per-session HMAC/Ed25519, key outside harness) and verified on load; verification failures alert via MIR-01 and block the action..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-14: Self-replication barrier

Self-replication barrier must hold. Prevent an injected instruction from being re-emitted through the agent's own output channels to propagate to other agents.

Real-world examples from the exploit catalog:

- **G29 — Self-Replication Barrier — Agent Output as a Worm-Class Propagation Vector:** catalogued attack pattern that exercises this control. CVEs: None |.
- Further evidenced by 2 catalogue incident(s): INC-71, INC-92.

What to look for in a typical deployment:

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Fingerprint matching quarantine with human approval; one-channel-per-write and human-signoff-on-broadcast; blast-radius cap per hop..

Often verified together: MS-01, MS-02, MS-03, MS-04.

MS-15: Cross-tenant agent memory and state isolation

Cross-tenant agent memory and state isolation must hold. Isolate multi-tenant agent memory and state per tenant as a hard boundary; keep the isolation key out of model control and gate retrieval/write by verified ownership.

Real-world examples from the exploit catalog:

- **G34 — Cross-Tenant Isolation in Pooled Agent Memory and Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-2018 · CVE-2026-2104 · CVE-2026-120306 · CVE-2026-120307. Canonical incidents: INC-81.

- Further evidenced by 4 catalogue incident(s): INC-81, INC-87, INC-91, INC-92.

What to look for in a typical deployment:

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Hard post-retrieval and post-write ownership gating with default-deny; connection parameters bound at construction; cross-tenant hits alarmed as control violations..

Often verified together: MS-01, MS-02, MS-03, MS-04.

IAM · Identity & Access

IAM-01: Agent identity management

Agent identity management must hold. Ensure every agent has a unique, lifecycle-managed digital identity distinct from human user identities, integrated with the organisation's identity provider.

Real-world examples from the exploit catalog:

- **G12 — Multi-Tenant Agent Platform Isolation:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-16, INC-50, INC-52.
- Further evidenced by 5 catalogue incident(s): INC-04, INC-16, INC-35, INC-52, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.identity = {"unique": bool, "auditable": bool}.` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-02, IAM-03, IAM-04, IAM-05.

IAM-02: Scope-bound delegation

Scope-bound delegation must hold. Limit each agent's permissions to the minimum set of tools, data, and actions required for its function, enforced by a policy-as-code engine at invocation time.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 10 catalogue incident(s): INC-04, INC-05, INC-09, INC-10, INC-15, INC-16.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.delegation = {"scoped": bool, "wildcard": bool}.` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-03, IAM-04, IAM-05.

IAM-03: Human oversight controls

Human oversight controls must hold. Implement risk-tiered human approval gates for agent actions, with documented break-glass procedures for urgent situations.

Real-world examples from the exploit catalog:

- **G14 — Inbound Agent-Platform Control-Plane Hijack:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-25253 · CVE-2026-59726 · CVE-2026-65105 · CVE-2026-82533. Canonical incidents: INC-21, INC-23, INC-24, INC-31.
- **G16 — Agent-Originated Artifact Publication:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-20.
- **G23 — Tool-Call Provenance and Dispatch Verification:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-18830 · CVE-2026-18236 · CVE-2026-64650 · CVE-2026-64651. Canonical incidents: INC-34.
- Further evidenced by 8 catalogue incident(s): INC-10, INC-20, INC-21, INC-23, INC-27, INC-34.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.high_risk_class ("financial" | "data_write" |` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Risk-based approval tiers. Automated approval gates. Time-limited approvals. Break-glass procedures documented..

Often verified together: IAM-01, IAM-02, IAM-04, IAM-05.

IAM-04: Credential isolation

Credential isolation must hold. Store, manage, and rotate agent credentials separately from human credentials with hardware-backed protection for critical agents and automated rotation on compromise signals.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 4 catalogue incident(s): INC-01, INC-04, INC-19, INC-21.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.credentials = {"isolated": bool, "hardware_backed":` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-05.

IAM-05: Just-in-time access

Just-in-time access must hold. Issue session-bound, ephemeral credentials for agents with automatic expiration and the ability to revoke mid-session on suspicious behaviour detection.

Real-world examples: none yet catalogued for this control — baseline coverage, not yet a documented failure mode.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.credentials = {"ephemeral": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

IAM-06: Cross-session boundary enforcement

Cross-session boundary enforcement must hold. Ensure each agent session is an independent security context with no credential or data sharing across sessions.

Real-world examples from the exploit catalog:

- **G12 — Multi-Tenant Agent Platform Isolation:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-16, INC-50, INC-52.
- Further evidenced by 2 catalogue incident(s): INC-50, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.session = {"independent_context": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

IAM-07: Transitive delegation chain enforcement

Transitive delegation chain enforcement must hold. Bound delegation chains and make them fully auditable.

Real-world examples from the exploit catalog:

- **G04 — Multi-Hop Identity Delegation Chain:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-02, INC-04, INC-05.
- Further evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.delegation = {"hops": n, "max_hops": 2,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

IAM-08: Credential scope narrowing

Credential scope narrowing must hold. Ensure credentials in agent environments are minimal, short-lived, and revocable.

Real-world examples from the exploit catalog:

- **G04 — Multi-Hop Identity Delegation Chain:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-02, INC-04, INC-05.
- Further evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.credentials = {"per_tool_scope": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

IAM-09: Multi-tenant agent platform isolation

Multi-tenant agent platform isolation must hold. Enforce data-layer tenant isolation on managed agent platforms.

Real-world examples from the exploit catalog:

- **G12 — Multi-Tenant Agent Platform Isolation:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-16, INC-50, INC-52.
- Further evidenced by 4 catalogue incident(s): INC-23, INC-35, INC-52, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.tenant = {"id": string, "scoped": bool};` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

IAM-10: Taint-tracked least-privilege subagent scoping

Taint-tracked least-privilege subagent scoping must hold. Taint-track externally-submitted records and bind subagent permission scoping to that taint plus field-level least privilege.

Real-world examples from the exploit catalog:

- **G32 — Taint-Tracked Least-Privilege Subagent Scoping:** catalogued attack pattern that exercises this control. CVEs: None |.
- Further evidenced by 2 catalogue incident(s): INC-72, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "data_read"; input.action.record.tainted =` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

- **The L3 bar** (the maturity target): Taint-marked at ingestion; record-handling subagents scoped to only required tables/fields/tools; tainted reads prevented from cascading into untainted sensitive collections..

Often verified together: IAM-01, IAM-02, IAM-03, IAM-04.

DS · Data Security

DS-01: Data classification and labelling

Data classification and labelling must hold. Classify all data entering the AI system at ingestion using an automated pipeline that feeds into downstream encryption, retention, and access controls.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 3 catalogue incident(s): INC-02, INC-15, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.data = {"classified": bool, "label": string}.` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: DS-02, DS-03, DS-04, DS-05.

DS-02: Inference data protection

Inference data protection must hold. Encrypt all data in transit between user, agent, model, and tools with TLS 1.3 minimum, and secure inference endpoints within the organisation's trust boundary for sensitive workloads.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-04.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.data.inference = {"encrypted_e2e": bool, "tls13_min": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: DS-01, DS-03, DS-04, DS-05.

DS-03: Memory sanitisation

Memory sanitisation must hold. Prevent persistence of sensitive data across sessions through automated purging, encryption, per-agent scoping, and cross-session aggregation detection.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 2 catalogue incident(s): INC-19, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.agent.memory = {"persists_classified": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: DS-01, DS-02, DS-04, DS-05.

DS-04: Data minimisation

Data minimisation must hold. Filter data at the retrieval layer (field-level, not document-level) and enforce attribute-based access control at query time to ensure agents receive only the minimum data required.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 2 catalogue incident(s): INC-23, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.data.access = {"bulk": bool, "field_filtered": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: DS-01, DS-02, DS-03, DS-05.

DS-05: Training data governance

Training data governance must hold. Track training data lineage from source to model, verify consent for personal data, enforce retention limits, and provide machine unlearning capability.

Real-world examples: none yet catalogued for this control — baseline coverage, not yet a documented failure mode.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.training.governance = {"lineage": bool, "retention_limited":` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: DS-01, DS-02, DS-03, DS-04.

DS-06: Output validation

Output validation must hold. Scan all model outputs for data leakage (PII, training data, system prompts, credentials) at the inference proxy layer before delivery to users or systems.

Real-world examples from the exploit catalog:

- **G07 — Side-Channel Detection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-11.
- Further evidenced by 6 catalogue incident(s): INC-02, INC-19, INC-22, INC-51, INC-71, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.output_scan = "clean" | "leak" | "pending".` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Automated output scanning for PII, sensitive data, system prompts, memorised training data. Scanning at application layer..

Often verified together: DS-01, DS-02, DS-03, DS-04.

DS-07: Agent-originated artifact publication control

Agent-originated artifact publication control must hold. Prevent agents from unintentionally or maliciously publishing execution-bearing artifacts into the software supply chain.

Real-world examples from the exploit catalog:

- **G16 — Agent-Originated Artifact Publication:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-20.
- Further evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "publication"; input.action.target = the` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

- **The L3 bar** (the maturity target): Signed, scanned, provenance-tracked publication pipeline; short-lived scoped credentials; agent cannot self-approve..

Often verified together: DS-01, DS-02, DS-03, DS-04.

DS-08: Destination and emergent-channel egress inventory

Destination and emergent-channel egress inventory must hold. Enumerate and control every outbound destination and channel that can carry agent data out of the boundary, using payload-blind allow-lists rather than classifiers.

Real-world examples from the exploit catalog:

- **G31 — Destination and Emergent-Channel Egress Inventory:** catalogued attack pattern that exercises this control. CVEs: None |. Canonical incidents: INC-72.
- Further evidenced by 2 catalogue incident(s): INC-72, INC-92.

What to look for in a typical deployment:

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Full channel inventory (URLs, DNS, image/render sources, messaging/unfurl, browser) each mapped to an explicit control; allow-list verification is payload-blind..

Often verified together: DS-01, DS-02, DS-03, DS-04.

TP · Tool & Pipeline Security

TP-01: Tool inventory and registry

Tool inventory and registry must hold. Maintain a central registry of all tools accessible to agents, with security review, versioning, and integration with the authorisation system.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 10 catalogue incident(s): INC-03, INC-04, INC-05, INC-08, INC-09, INC-10.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.tool = the tool being invoked. The registry below` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Central tool registry with full metadata. Automated security review. Integration with authorisation..

Often verified together: TP-02, TP-03, TP-04, TP-05.

TP-02: Tool access control

Tool access control must hold. Enforce per-agent tool allow-lists at invocation time with authenticated agent identity and version-controlled, auditable access policies.

Real-world examples: none yet catalogued for this control — baseline coverage, not yet a documented failure mode.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.tool_auth = {"agent_authenticated": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-03, TP-04, TP-05.

TP-03: API gateway security

API gateway security must hold. Deploy a gateway between agents and tools that enforces rate limiting, schema validation, audit logging, and MCP protocol awareness where applicable.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 9 catalogue incident(s): INC-01, INC-04, INC-07, INC-08, INC-12, INC-13.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.gateway = {"rate_limited": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-04, TP-05.

TP-04: Tool output validation

Tool output validation must hold. Validate all tool outputs against known-good schemas before passing to agent context, with content-type verification, size limits, and sandboxed execution for code-generation tools.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 13 catalogue incident(s): INC-03, INC-05, INC-09, INC-11, INC-12, INC-13.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.tool_output = {"validated": bool, "sanitised": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-03, TP-05.

TP-05: Pipeline integrity

Pipeline integrity must hold. Sign and attest all CI/CD pipeline runs, enforce security gates before deployment, and store deployment artifacts in an immutable, integrity-verified registry.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 8 catalogue incident(s): INC-01, INC-05, INC-07, INC-19, INC-22, INC-47.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.pipeline = {"run_signed": bool, "attested": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-06: Dependency scanning

Dependency scanning must hold. Continuously scan all ML libraries, model dependencies, tool SDKs, and container images for vulnerabilities with automated blocking of critical-severity findings.

Real-world examples from the exploit catalog:

- **G09 — MCP Protocol-Layer Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-12, INC-37, INC-54.
- **G25 — Agent Dependency-Install Provenance (Dangling-Install Poisoning):** catalogued attack pattern that exercises this control. CVEs: None (design/ provenance class · no CVE) |.
- **G27 — In-Process Denylist/Blocklist Code-Execution Sandbox Bypass:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-47392 (PraisonAI · Critical) · CVE-2026-37008 (CrewAI · 8.1). Canonical incidents: INC-58, INC-68, INC-74, INC-76.

- Further evidenced by 9 catalogue incident(s): INC-07, INC-13, INC-18, INC-19, INC-38, INC-44.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.dependencies = {"scanned": bool, "critical_finding": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-07: Cross-tool dependency analysis

Cross-tool dependency analysis must hold. Detect and gate escape-class tool combinations before deployment.

Real-world examples from the exploit catalog:

- **G02 — Cross-Tool Dependency and Chain Analysis:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-02, INC-03, INC-04.
- Further evidenced by 2 catalogue incident(s): INC-12, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.tools = {"chain_analysed": bool, "escape_chain": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-08: API gateway infrastructure-isolation mode

API gateway infrastructure-isolation mode must hold. Prevent agents from reaching cloud infrastructure control planes.

Real-world examples from the exploit catalog:

- **G03 — Infrastructure API vs Tool API Confusion:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-04, INC-07.
- Further evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.gateway = {"infra_isolation": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-09: Explicit tool registration — no implicit tool exposure

Explicit tool registration — no implicit tool exposure must hold. Eliminate implicit tool exposure in agent frameworks.

Real-world examples from the exploit catalog:

- **G13 — Implicit Tool Exposure:** catalogued attack pattern that exercises this control. CVEs: (no CVE list).
- **G23 — Tool-Call Provenance and Dispatch Verification:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-18830 · CVE-2026-18236 · CVE-2026-64650 · CVE-2026-64651. Canonical incidents: INC-34.
- **G26 — Agent Extension/Skill Execution Integrity:** catalogued attack pattern that exercises this control. CVEs: None directly; ClawHub skills delivered AMOS via infrastructure at glot[.]io and attacker-controlled GitHub releases |. Canonical incidents: INC-48.

- Further evidenced by 5 catalogue incident(s): INC-11, INC-34, INC-46, INC-48, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind in {"tool_call","dispatch"};` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Auto-registration disabled by default; all callables audited; unregistered callables blocked..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-10: Agent platform inbound control-plane protection

Agent platform inbound control-plane protection must hold. Defend the agent platform's inbound listening surface from direct, model-independent attack.

Real-world examples from the exploit catalog:

- **G12 — Multi-Tenant Agent Platform Isolation:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-16, INC-50, INC-52.
- **G14 — Inbound Agent-Platform Control-Plane Hijack:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-25253 · CVE-2026-59726 · CVE-2026-65105 · CVE-2026-82533. Canonical incidents: INC-21, INC-23, INC-24, INC-31.
- **G18 — Agent Self-Exposure:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-23, INC-24, INC-69.
- **G33 — Tool-Connection and Launch-Path Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2025-6514 · CVE-2026-103572 · CVE-2026-123022 · CVE-2026-110186. Canonical incidents: INC-79, INC-80, INC-85, INC-86.
- Further evidenced by 13 catalogue incident(s): INC-24, INC-30, INC-31, INC-32, INC-34, INC-39.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "binding"; input.action.target = listener;` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Default-deny binding policy enforced; no standing allow rules; automated detection of new listeners; no operator-scope tokens readable from web context..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-11: Agent browser and content-rendering isolation

Agent browser and content-rendering isolation must hold. Prevent untrusted rendered content from commanding the agent.

Real-world examples from the exploit catalog:

- **G15 — Imperceptible-Content Injection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-20, INC-22, INC-25, INC-27.
- **G21 — Agentic-Browser Content Isolation:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-30, INC-29, INC-27.
- Further evidenced by 4 catalogue incident(s): INC-29, INC-30, INC-42, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.cross_origin (bool), input.action.privileged (bool),` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Origin isolation preserved in agent browser runtimes; no cross-origin token access; imperative action gating (approval

required for financial and credential operations); document uploads sanitised before assistant processing..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-12: Tool-call provenance and dispatch verification

Tool-call provenance and dispatch verification must hold. Ensure no tool executes without verified provenance from an authorised model turn or caller.

Real-world examples from the exploit catalog:

- **G23 — Tool-Call Provenance and Dispatch Verification:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-18830 · CVE-2026-18236 · CVE-2026-64650 · CVE-2026-64651. Canonical incidents: INC-34.
- Further evidenced by 8 catalogue incident(s): INC-11, INC-34, INC-41, INC-44, INC-46, INC-53.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "dispatch"; input.action.provenance =` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Tool calls carry cryptographically bound provenance (session, turn, model signature) verified before dispatch; session/event history authenticated; approval records bind to tool name and arguments and verify against the human approver channel; fail closed on unverifiable provenance..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-13: Agent dependency-install provenance verification

Agent dependency-install provenance verification must hold. Verify registry-namespace and domain-ownership provenance before any agent-executed install derived from ingested content.

Real-world examples from the exploit catalog:

- **G25 — Agent Dependency-Install Provenance (Dangling-Install Poisoning):** catalogued attack pattern that exercises this control. CVEs: None (design/ provenance class · no CVE) |.
- Further evidenced by 7 catalogue incident(s): INC-44, INC-48, INC-66, INC-80, INC-85, INC-86.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "dependency_install". Installation commands` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Pre-install provenance verification: registry existence, namespace ownership, domain registration; installs from untrusted content gated by an allowlist or human approval; dangling references blocked and logged via MIR-01..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-14: Skill/plugin payload integrity and instruction-channel isolation

Skill/plugin payload integrity and instruction-channel isolation must hold. Gate every agent extension install on signed, immutable payloads with no runtime-fetchable instruction channels and privilege-scoped execution.

Real-world examples from the exploit catalog:

- **G26 — Agent Extension/Skill Execution Integrity:** catalogued attack pattern that exercises this control. CVEs: None directly; ClawHub skills delivered AMOS via infrastructure at glot[.]io and attacker-controlled GitHub releases |. Canonical incidents: INC-48.
- Further evidenced by 3 catalogue incident(s): INC-48, INC-66, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "skill_execute" (a skill/plugin about to run).` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Immutable signed payloads; runtime-fetch channels blocked; privilege-scoped execution; post-install baseline with drift quarantine..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-15: In-process code-execution sandbox sufficiency

In-process code-execution sandbox sufficiency must hold. Route all LLM-generated or untrusted code execution to an OS/VM-isolated execution environment; never rely on an in-process denylist/blocklist interpreter gate as the boundary.

Real-world examples from the exploit catalog:

- **G27 — In-Process Denylist/Blocklist Code-Execution Sandbox Bypass:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-47392 (PraisonAI · Critical) · CVE-2026-37008 (CrewAI · 8.1). Canonical incidents: INC-58, INC-68, INC-74, INC-76.
- Further evidenced by 11 catalogue incident(s): INC-58, INC-65, INC-68, INC-74, INC-76, INC-77.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "code_execution". LLM-generated or untrusted` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

- **The L3 bar** (the maturity target): In-process sandboxes locked in the HIGH-RISK dependency class (TP-06) with automated blocking on critical findings; model-generated code executes only in the EE sandbox..

Often verified together: TP-01, TP-02, TP-03, TP-04.

TP-16: Tool-connection and launch-path integrity

Tool-connection and launch-path integrity must hold. Keep remote peer-supplied protocol metadata (OAuth/discovery/connection fields) out of process-launch and shell execution primitives; origin-bound and validate the authorization endpoint.

Real-world examples from the exploit catalog:

- **G30 — Agent-Identity Outbound Communication Attribution and Confirmation:** catalogued attack pattern that exercises this control. CVEs: None (architectural) |. Canonical incidents: INC-72.
- **G33 — Tool-Connection and Launch-Path Execution:** catalogued attack pattern that exercises this control. CVEs: CVE-2025-6514 · CVE-2026-103572 · CVE-2026-123022 · CVE-2026-110186. Canonical incidents: INC-79, INC-80, INC-85, INC-86.
- Further evidenced by 6 catalogue incident(s): INC-79, INC-85, INC-86, INC-88, INC-89, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.kind == "tool_connect" / "tool_launch". Remote` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Authorization endpoint origin-bound and validated on canonical value; no transport field crosses into a launch/shell primitive; launch commands allowlisted; connection termination and alert on any violation..

Often verified together: TP-01, TP-02, TP-03, TP-04.

MIR · Monitoring, Logging & IR

MIR-01: Agent activity logging

Agent activity logging must hold. Log all agent actions in structured format with immutable storage, SIEM integration, and distributed tracing support for multi-agent architectures.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 10 catalogue incident(s): INC-01, INC-05, INC-06, INC-08, INC-12, INC-16.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.audit_record (bool) -- the action carries a` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Immutable logs. Correlation IDs across multi-agent chains. SIEM integration. Log integrity verification..

Often verified together: MIR-02, MIR-03, MIR-04, MIR-05.

MIR-02: Anomaly detection

Anomaly detection must hold. Establish per-agent and per-agent-class behaviour baselines for tool usage, data access, memory access, and decision patterns, with automated alerting on deviation.

Real-world examples from the exploit catalog:

- **G07 — Side-Channel Detection:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-01, INC-11.
- **G18 — Agent Self-Exposure:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-23, INC-24, INC-69.

- **G19 — Attacker-Side Autonomous AI:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-23, INC-35, INC-36, INC-40.
- **G20 — Agent Memory-Store Poisoning:** catalogued attack pattern that exercises this control. CVEs: CVE-2026-59726 (CVSS 10.0) · CVE-2026-65105 |. Canonical incidents: INC-31.
- **G22 — Operational Data-Stream Poisoning:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-33.
- **G26 — Agent Extension/Skill Execution Integrity:** catalogued attack pattern that exercises this control. CVEs: None directly; ClawHub skills delivered AMOS via infrastructure at glot[.]io and attacker-controlled GitHub releases |. Canonical incidents: INC-48.
- Further evidenced by 18 catalogue incident(s): INC-06, INC-08, INC-10, INC-19, INC-23, INC-27.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.anomaly_flag (bool) -- the platform's baseline` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Per-agent and per-class baselines. Automated alerting. Integration with SOC. Regular tuning..

Often verified together: MIR-01, MIR-03, MIR-04, MIR-05.

MIR-03: Prompt audit log

Prompt audit log must hold. Log prompt/response pairs with automated sensitive data redaction, tiered retention, and SIEM integration for forensic analysis.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-22.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.sensitive (bool) -- the action involves sensitive` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Automated redaction. Tiered retention (full -> redacted). SIEM integration..

Often verified together: MIR-01, MIR-02, MIR-04, MIR-05.

MIR-04: Incident response

Incident response must hold. Develop and maintain AI-specific IR playbooks covering prompt injection, model compromise, tool abuse, and code-generation attacks, tested through regular tabletop exercises.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 3 catalogue incident(s): INC-07, INC-16, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.incident = {"playbook": string, "containment": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: MIR-01, MIR-02, MIR-03, MIR-05.

MIR-05: Mandatory reporting integration

Mandatory reporting integration must hold. Integrate incident detection with automated regulatory reporting triggers for SOCI Act, APRA CPS 234, and Notifiable Data Breaches, with pre-populated report templates.

Real-world examples: none yet catalogued for this control — baseline coverage, not yet a documented failure mode.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.incident (bool); input.action.reporting_triggered` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Automated incident detection triggers pre-populated reports. Escalation workflows active..

Often verified together: MIR-01, MIR-02, MIR-03, MIR-04.

MIR-06: Forensic readiness

Forensic readiness must hold. Maintain immutable, verifiable logs with full session reconstruction capability for all agents, including support for multi-agent chain reconstruction.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 6 catalogue incident(s): INC-07, INC-40, INC-46, INC-53, INC-70, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.high_impact (bool); input.action.reconstructible` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.
- **The L3 bar** (the maturity target): Immutable logs with integrity verification. Full session reconstruction capability. Multi-agent chain reconstruction..

Often verified together: MIR-01, MIR-02, MIR-03, MIR-04.

GRM · Governance & Risk

GRM-01: AI governance body

AI governance body must hold. Establish and charter an AI governance body with cross-functional membership (CISO, CRO, GC, data owner, AI lead) and defined decision authority over agentic AI deployments.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.governance.body = {"chartered": bool, "cross_functional":` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-02, GRM-03, GRM-04, GRM-05.

GRM-02: AI risk register

AI risk register must hold. Maintain a dedicated AI risk register using a threat taxonomy that covers model, tool, data, identity, and pipeline risks, with defined owners, assessment methodology, and review cadence.

Real-world examples from the exploit catalog:

- **G19 — Attacker-Side Autonomous AI:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-23, INC-35, INC-36, INC-40.
- Further evidenced by 6 catalogue incident(s): INC-06, INC-32, INC-35, INC-49, INC-55, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.governance.risk = {"registered": bool,` and fails closed if it is

absent. Instrument every deployment source to confirm this signal reaches the evaluator.

- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-01, GRM-03, GRM-04, GRM-05.

GRM-03: Ethical use policy

Ethical use policy must hold. Document and enforce an ethical use policy that classifies agents by risk tier, defines autonomy boundaries per tier, and specifies transparency obligations.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 3 catalogue incident(s): INC-10, INC-32, INC-42.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.action.acceptable (bool) -- the action is inside the` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-01, GRM-02, GRM-04, GRM-05.

GRM-04: Third-party AI risk management

Third-party AI risk management must hold. Assess and monitor third-party AI providers for security controls, with contractual security requirements and right-to-audit provisions in all AI-related procurement.

Real-world examples from the exploit catalog:

- **G17 — Evaluation-Harness Integrity:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-19, INC-01, INC-26, INC-27.

- **G19 — Attacker-Side Autonomous AI:** catalogued attack pattern that exercises this control. CVEs: (no CVE list). Canonical incidents: INC-23, INC-35, INC-36, INC-40.
- Further evidenced by 6 catalogue incident(s): INC-26, INC-62, INC-63, INC-75, INC-90, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.vendors = {"assessed": bool, "contractual_controls": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-01, GRM-02, GRM-03, GRM-05.

GRM-05: Regulatory mapping and compliance reporting

Regulatory mapping and compliance reporting must hold. Maintain an automated mapping of SHIELD-AI controls to applicable regulatory frameworks with continuous compliance monitoring and regular reporting.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 1 catalogue incident(s): INC-16.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.governance.compliance = {"mapped": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-01, GRM-02, GRM-03, GRM-04.

GRM-06: Board and executive reporting

Board and executive reporting must hold. Provide a standardised executive dashboard showing pillar maturity scores, open findings, regulatory compliance status, and risk acceptances, refreshed automatically.

Real-world examples from the incident catalogue:

- Not yet directly exercised by a catalogued exploit type, but evidenced by 3 catalogue incident(s): INC-73, INC-90, INC-92.

What to look for in a typical deployment:

- **Is the input signal ever missing?** The policy evaluates `input.governance.reporting = {"dashboard": bool,` and fails closed if it is absent. Instrument every deployment source to confirm this signal reaches the evaluator.
- **Where would you see a violation?** Confirm the fail-closed conditions in doc 06 are wired into your detection/alerting pipeline, not only the enforcement point.

Often verified together: GRM-01, GRM-02, GRM-03, GRM-04.
